

MID-STATE TECHNICAL COLLEGE • IT PROGRAMS

Introduction, Ethics, and Purpose

Unit 1 • Ethical Hacking (10-151-160)



Learning Outcomes



Classify an access scenario

Separate authorized testing from gray-hat disclosure and criminal access.



Apply computer crime law

Identify which CFAA offenses a described act implicates — and what the law does not protect.



Evaluate an engagement agreement

Review a scope of work and flag what is missing or dangerously vague.



Map an intrusion to the lifecycle

Place each step of a real breach on the current MITRE ATT&CK matrix.



Read a penetration test report

Separate risk from complexity, and finding from recommendation.

LESSON 1

Defining Ethical Hacking



What Is Ethical Hacking?

An information security professional who systematically attempts to penetrate a system — on behalf of its owners, and with their permission — to find vulnerabilities an attacker could exploit.

- **Systematically** — a repeatable methodology, not poking at whatever looks interesting.
- **On behalf of its owners** — the owner is the client, and the owner defines success.
- **With their permission** — written, signed, and dated before testing starts.
- **Vulnerabilities** — the deliverable is findings and remediation guidance, not trophies.



Every word is a control

Strip any one clause and the same keystrokes become a felony. Skill is not what makes this legal — paperwork is.

What Ethical Hacking Is Not

It Is

- Performed under a signed engagement agreement
- Bounded by an explicit scope and target list
- Reported to the owner before anyone else
- Conducted inside a jurisdiction you verified
- Sometimes a public bug bounty — within its rules

It Is Not

- Disclosing flaws for the "greater good" (gray hat)
- Freely seeking out flaws on systems you do not own
- Vigilantism — hacking back at criminals or scammers
- Hacktivism, however sympathetic the cause
- Anything that puts you above the law or your contract

The dividing line: Not technique, not intent, not outcome — authorization. Everything else is commentary.

Hat Colors, and Where the Metaphor Leaks

A useful shorthand, as long as you remember the law only recognizes two of these:

Hat	What they do	Legal standing
White	Tests with authorization, in scope, reports to the owner	Protected by contract
Gray	Finds flaws uninvited, then discloses them	Unauthorized access
Black	Unauthorized access for gain, disruption, or ideology	Unauthorized access

Two of these three rows describe the same crime. Only the motive differs, and motive is argued after the arrest.

LESSON 2

Ethics and the Law



Information Access Ethics

You will routinely be able to see things you have no business seeing. Difficulty tells you nothing about permission.

- **Capability is not consent** — being able to read a file does not mean you may read it.
- **Context changes the answer** — a patient record carries HIPAA duties a spreadsheet does not.
- **Illegal material** — stop, do not investigate, escalate through the agreed channel.
- **Scope creep is a decision** — if you are wondering whether it is in scope, it is a question for the client.



SECURITY FOCUS

The moment you access something outside the agreed scope, you have left the protection of the contract — even if you found it by accident and reported it immediately.

Why it matters: Your authorization is only as wide as the document, and the document is what a prosecutor reads.

Case Study: Missouri, 2021

A reporter found 100,000+ Social Security numbers in the HTML source of a state education website.

- **The technique** — viewing page source in a browser. Available to every visitor with an `F12` key.
- **The disclosure** — notified the state, held publication until the data was secured.
- **The response** — the governor called him a hacker and pushed publicly for prosecution.
- **The outcome** — charges declined in February 2022, after four months of criminal investigation.



Being right is not enough

He did everything a disclosure guide recommends and still spent four months as a suspect. Counsel and documentation are not paranoia — they are the job.

The Computer Fraud and Abuse Act

The primary U.S. federal computer crime statute — and the reason engagement agreements exist.

Offense	Penalty (prison)
Obtaining national security information	10 years; 20 on a second conviction
Accessing a computer to defraud and obtain value	5 years; 10 on a second conviction
Accessing a computer and obtaining information	1–5 years; 10 on a second conviction
Intentionally damaging by knowing transmission	1–10 years; 20 on a second conviction
Extortion involving computers	5 years; 10 on a second conviction
Trafficking in passwords	1 year; 10 on a second conviction

18 U.S.C. § 1030. Penalties escalate sharply on a second conviction — this is not a statute you learn by testing it.

What Changed Since the Statute Was Written

Van Buren v. United States (2021)

- The Supreme Court narrowed "exceeds authorized access"
- It does not cover accessing data you are entitled to see for an improper purpose
- Violating a terms-of-service or workplace policy is no longer automatically federal crime

DOJ Charging Policy (May 2022)

- Directs prosecutors to decline charges for good-faith security research
- Requires consulting the Computer Crime and IP Section before any CFAA charge
- Good faith is defined: solely to find or fix a flaw, avoiding harm, never for extortion

Direction of travel: Both developments narrow the statute — but neither one is a permission slip.

What That Policy Does Not Do

- **It is policy, not law** — internal DOJ guidance, revisable by a future administration without Congress.
- **It does not touch civil liability** — a company can still sue you under the CFAA's civil provisions.
- **It does not preempt state law** — Wisconsin and every other state have their own statutes and prosecutors.
- **It does not cross borders** — a host that resolves overseas puts you under that country's law.



SECURITY FOCUS

A signed engagement agreement protects you in all four of these gaps. A favorable charging policy protects you in exactly one, and only for as long as it stands.

Why it matters: Never let a legal trend do the job a contract is supposed to do.

The Engagement Agreement

Everything that makes your work legal lives in a document signed before the first packet leaves your machine.

- **Non-disclosure agreement** — protects what you will inevitably learn about the client's business.
- **Scope of work** — named systems, IP ranges, domains. Anything unnamed is out of scope.
- **Authorization letter** — the "get out of jail free" statement: testers, targets, and window.
- **Customer signature** — from someone with actual authority to grant access to those systems.



Ask about the landlord

Cloud and hosting providers may need to authorize testing on infrastructure your client only rents. The client cannot consent on their behalf.

Rules of Engagement

Boundaries

- Testing windows and blackout periods
- Permitted techniques — is social engineering in play?
- Whether denial of service is authorized at all
- Territory: which states and countries are involved

Handling

- Escalation path — who gets called, and how fast
- Stop conditions that halt testing immediately
- How captured evidence is stored, sent, and destroyed
- Deliverable format and whether a retest is included

Do this once: Have an attorney review your template the first time. Reuse it after that — but re-scope it every engagement.

LESSON 3

The Anatomy of an Attack



Why Ethical Hackers Exist

Organizations do not pay for attacks. They pay for the information an attack produces.

The reason	What it actually buys the client
Find flaws first	Someone will find it. The question is whether they are under contract to tell you.
Validate the structure	A control on an architecture diagram is not a control until something tests it.
Stay current	Attacker tradecraft moves faster than documentation. Practice is how defenders keep up.
Satisfy requirements	PCI DSS, HIPAA, SOC 2, and cyber insurance all want evidence of testing.

We need people who can figure out how to break the world, so the cracks get fixed before someone else exploits them.

The Attack Lifecycle

Intrusions are campaigns, not events. Naming the phase tells a defender where the attacker is right now.

Phase	What is happening	Defender's cue
Initial access	The first foothold is established	You have been compromised
Persistence	Surviving reboots and password resets	Odd scheduled tasks, new services
Privilege escalation	From the account they got to the one they need	Anomalous rights changes
Lateral movement	Spreading to other hosts	East-west traffic that should not exist
Data discovery	Locating what is worth taking	Unusual share and database access
Exfiltration	Data leaves the environment	You have been breached
Cleanup	Log manipulation, artifact removal	Gaps in logs you cannot explain

Escalation and lateral movement often trade places, or repeat. The order is a model, not a rule.

Two Ways to Model It

Cyber Kill Chain

- Linear, high-level narrative of one campaign
- Built for briefing non-technical stakeholders
- Good for asking "where could we have broken this?"
- Not one size fits all — you build one per threat

MITRE ATT&CK

- A behavioral matrix of tactics and techniques
- Tactic = the attacker's goal; technique = how
- Built from observed real-world adversary activity
- The shared vocabulary of reports, detections, and interviews

LIVE DEMO

Open attack.mitre.org and walk one tactic column end to end.

ATT&CK Is a Moving Target

The framework is versioned and changes materially between releases. Cite the version you used.

- The **April 2026 v19** release retired **Defense Evasion** and split it into two tactics.
- **Stealth (TA0005)** — avoiding notice while your defenses keep running: obfuscation, process injection, indicator removal.
- **Defense Impairment (TA0112)** — breaking defenses outright: killing endpoint protection, tampering with logging.
- Enterprise ATT&CK now carries **15 tactics** — every older write-up you read still says "Defense Evasion."



SECURITY FOCUS

The split answers a question the old tactic could not: did our tools miss the attacker, or did the attacker turn them off?

Why it matters: Those are very different incidents, and they call for very different responses.

LESSON 4

Know Your Enemy



What Motivates Attackers

Infer the likely motive from what a target holds, then defend accordingly.

Organized and Directed

- **Profit** — ransomware, extortion, card theft, data resale
- **Espionage** — intelligence for a state or a competitor
- **Politics / social justice** — hacktivism and state objectives
- **Sabotage** — damaging infrastructure and critical systems

Personal and Opportunistic

- **Ideology** — acting for a cause without formal direction
- **Extortion** — coercion for something other than money
- **Ego or vanity** — fame; victims found by scanning, claimed as targets
- **Revenge / trolling** — the ex-employee with live credentials

Categories from IBM X-Force threat research. Real campaigns routinely run several of these at once.

The 2026 Threat Landscape

Motives held steady. How attackers get in did not.

- **Vulnerabilities overtook credentials** — exploitation was the leading initial access vector for the first time in the DBIR's 19-year history, at roughly 31% of breaches.
- **Public-facing apps under pressure** — X-Force saw a 44% rise in attacks starting there, driven by missing authentication.
- **The extortion market fragmented** — 49% more active ransomware and extortion groups year over year.
- **Supply chain became the path** — large third-party compromises nearly quadrupled since 2020: CI/CD, package registries, SaaS integrations.



AI changed speed, not motive

Nobody's reason for attacking changed. What collapsed is the time from public disclosure to a working exploit — which is a patching problem, not a new threat category.

LESSON 5

Where an Engagement Ends



Anatomy of a Penetration Test Report

Every technique in this course terminates in a document. This is the shape of it.

- **Confidentiality and disclaimers** — handling rules, and the point-in-time caveat.
- **Purpose and scope** — what was tested, what was not, accounts provided, what was broken.
- **Findings matrix** — vulnerabilities tallied by category and severity, at a glance.
- **Individual findings** — summary, reproduction steps, evidence, recommended resolution.
- **Conclusion** — the remediation summary leadership will read even if they read nothing else.



Report what you did not find

Testing categories that produced nothing still belong in the report. Negative results are evidence of coverage — and the client paid for that coverage.

Risk and Complexity Are Different Questions

Risk — how bad if exploited?

- Driven by the data or capability exposed
- A flaw exposing patient records rates High no matter how hard it is to reach
- Maps to the client's regulatory and business exposure

Complexity — how hard to pull off?

- Driven by prerequisites: authentication, positioning, tooling, timing
- "Intercept a POST and delete a field" is Low and trivially repeatable
- Says nothing about how much damage it does

Read the pair, not the label: High risk plus low complexity is the finding that gets remediated first. Rating either one alone tells the client nothing.

Methodologies Behind the Structure

Reports look alike across firms because most are built on one of a few published methodologies.

Methodology	What it is for
NIST SP 800-115	Federal technical guide — planning, discovery, attack, reporting. Heavy on authorization.
OWASP WSTG	The de facto standard for web application testing; a catalog of specific test cases.
PTES	The full engagement lifecycle, from pre-engagement interactions through the report.
MITRE ATT&CK	Not a testing methodology — the vocabulary for describing findings as adversary behavior.

Recognition level for now. You will work inside OWASP WSTG in depth later this term.

The Thread Running Through This Unit

Every lesson today circled the same idea from a different direction.



SECURITY FOCUS

The techniques you learn this semester are neutral. The same port scan, the same intercept proxy, the same credential dump is a professional service or a federal offense depending entirely on a document you signed before you started — and on whether you stayed inside it once things got interesting.

Why it matters: The contract is a security control, and it is the only one in this course that protects you rather than the client.

Hands-On: Unit 1 Lab

TryHackMe and Hack The Box · accounts required before Unit 2

- **Assignment 1** — define and document the note-taking system you will use all term.
- Create accounts on **TryHackMe** and **Hack The Box**; complete the welcome survey.
- Complete **Intro to Offensive Security** and start the **Jr Penetration Tester** path on TryHackMe.
- Read each platform's terms of service — note what they do and do not authorize you to do.



The note-taking plan is graded on whether it could reconstruct a finding six weeks from now — not on which app you chose.

Key Takeaways



Authorization — not technique, intent, or outcome — is what makes hacking ethical.



The CFAA is narrower than it was, but policy is not law and states prosecute their own.



The engagement agreement is a security control. Read it before you read a manual.



Name the phase and cite the ATT&CK version — v19 split Defense Evasion in two.



Every engagement ends in a report. Risk and complexity are separate questions.

MID-STATE TECHNICAL COLLEGE · IT PROGRAMS

Questions?

Unit 1 · Introduction, Ethics, and Purpose

